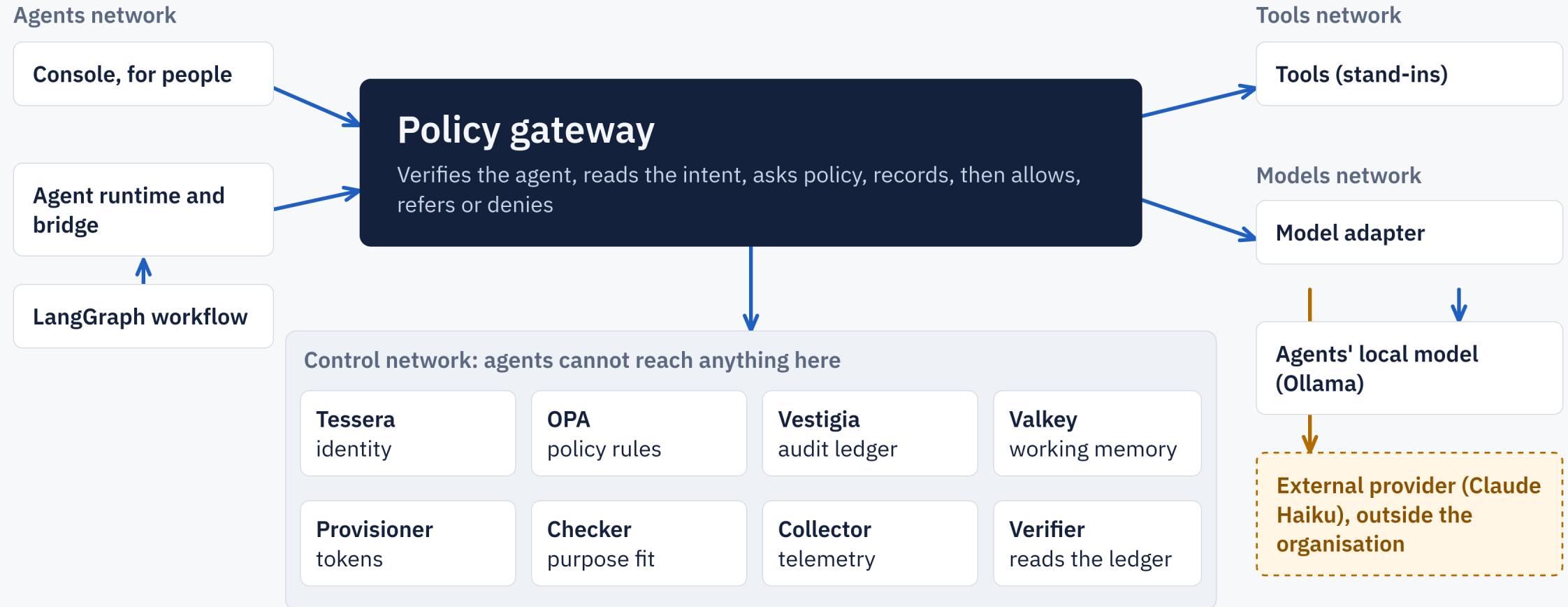


The policy gateway: its components

What each one does, what it holds, who can reach it, and what happens without it

The components around the policy gateway



The gateway is the only component on all four networks. The model adapter alone has a route out.

Policy gateway

The enforcement point: every tool call and model call from an agent arrives here and nowhere else.

What it does

Verifies the agent, reads the declared intent, asks the policy engine, writes the decision to the ledger, then calls the tool or model, holds the call for a reviewer, or refuses it. On a model call it first removes tools outside the agent's role.

What it holds

The reviewer key, the ledger's key, the model adapter's key and the store's password. No identity admin key and no provider key.

Who can reach it

Agents, on the agents network. It is the only component on all four networks.

If it is unavailable

Nothing an agent does can proceed. Agents have no other route.

Measured: 4 to 5 ms for identity, policy and limits, before the audit write. **Limits:** it verifies the agent, not the person. It does not inspect tool responses.

Open Policy Agent

The decision point: it holds the rules and the registry, and answers one question per call.

What it does

Evaluates two policies, one for tools and one for models, against a registry of roles, purposes, tools, models and limits. Returns deny, refer or allow with reasons, plus the tools a model may be shown, the token ceiling and the hold timeout.

What it holds

The policy files and the registry, mounted read-only. No secrets.

Who can reach it

The gateway only.

If it is unavailable

Every call is denied.

Measured: 1.1 ms per decision, with 35 policy tests. **Limits:** it sees the purpose code, not the words of the request. The registry values are examples.

Tessera

The identity service: it issues and validates each agent's credentials.

What it does

Issues a signed token valid for one tool, for 15 minutes, bound to the agent's own key. Validates a token together with the agent's proof that it holds that key, made for the gateway's address and usable once. Revokes tokens.

What it holds

The token signing secret and the list of registered agents with the tools each may hold tokens for.

Who can reach it

The gateway, to validate. The provisioner, to register agents and issue tokens.

If it is unavailable

Every call is denied, because no identity can be verified.

Measured: 2.9 ms per validation. **Limits:** its revoke, validate and agent-list endpoints accept calls without a credential, so it must stay unreachable by agents.

Provisioner

Enrols agents and hands out tokens, so the identity admin key lives in one small place.

What it does

Takes an operator's request to enrol an agent with its public key and role. Gives an agent a token when the agent proves it holds the enrolled key: one token per tool, and one for the model path.

What it holds

The identity service's admin key and the operator key. It is the only holder of the admin key: neither the gateway nor any agent has it.

Who can reach it

Agents, to ask for their own tokens. The console, to enrol agents with the operator key.

If it is unavailable

No new tokens. Tokens already issued work until they expire, within 15 minutes.

Limits: which tools a role may hold tokens for comes from the registry, so an error there is an error here.

Vestigia

The audit ledger: a tamper-evident record of every decision.

What it does

Appends each event to a file in which every entry carries a keyed hash of its own contents and of the entry before it. Changing, removing or inserting an entry breaks the chain.

What it holds

The ledger file, the hashing secret and its own access key. Each entry names the agent, the person, the purpose, the decision and its reasons.

Who can reach it

The gateway and the provisioner, to write.

If it is unavailable

Every call is denied. Audit fails closed: no record, no call.

Measured: 57 to 180 ms per write as the ledger grew from 600 to 4,500 entries: 95 per cent or more of a request's time. **Limits:** each write rewrites the whole file. Its own integrity check twice called a sound chain invalid.

Valkey

The gateway's working memory: fast storage for state that must outlive one request.

What it does

Remembers held calls and makes sure an approval is used exactly once. Keeps the review queue and the latest 1,000 flags for the console. Counts calls per minute and tokens per day for the limits.

What it holds

Short-lived state only. Nothing in it is evidence: every decision, hold and flag is also written to the ledger.

Who can reach it

The gateway only, with a password.

If it is unavailable

Every call is denied, because limits and holds cannot be checked.

Measured: under 1 ms per request. **Limits:** not hash-chained, and old flags drop off the end of the list.

OpenTelemetry Collector

The observability plane's collection point for traces and metrics.

What it does

Receives one trace per request from the gateway, with a span for each stage, plus a decision counter and a duration histogram. Keeps every denial, referral and failure, and one in ten allowed calls.

What it holds

Timing and outcome data, written to files. No tool parameters and no prompt content are sent to it.

Who can reach it

The gateway only.

If it is unavailable

Nothing changes for callers. Telemetry fails open, unlike audit.

Link to the ledger: the trace identifier is the same in both, and is shown on each step in the console. **Limits:** only the gateway is instrumented, and no dashboard is attached.

Checking model

The control plane's own model, for one job: does this request fit its declared purpose?

What it does

Given a purpose's description and the newest request, answers "fits" or "mismatch" with a short reason. The gateway asks after allowing a model call, once per distinct request, including each reply. A mismatch is flagged for review.

What it holds

The model's files and nothing else. It is not in the model registry, so no agent can ask for it.

Who can reach it

The gateway only, directly. It is a separate server from the model agents use.

If it is unavailable

Requests are recorded as "not checked". Calls are unaffected: the check never blocks.

Observed: six of six off-purpose requests flagged. **Limits:** a small model that can be wrong both ways. Its false alarm rate is not measured.

Model adapter

The one component that talks to model providers, and the only one with a route out.

What it does

Takes a model call the gateway has already allowed and translates it for its destination: the external provider, the agents' local model, or a stand-in for tests. It makes no decisions of its own.

What it holds

The provider's key. No agent, and not even the gateway, ever sees it.

Who can reach it

The gateway only, with a key that only the gateway holds.

If it is unavailable

Model calls are denied. Tool calls are unaffected.

Measured: 4.2 ms with the stand-in model. **Limits:** its route out is not yet restricted to the provider's addresses.

Agents' local model

A model inside the organisation that agents may be allowed to use.

What it does

Answers model calls that policy has routed to the model named local-model. Nothing in such a call leaves the organisation. Policy decides by role which agents may use it and which may use the external provider.

What it holds

The model's files. Ollama has no access control of its own, which is why it sits behind the adapter.

Who can reach it

The model adapter only. It has no route out.

If it is unavailable

Calls to the local model fail. Other models are unaffected.

Observed: in its first real run it skipped the database and invented sales figures, with every call permitted. **Limits:** a 3 GB model keeps data inside but is weaker at using tools.

Agent runtime and bridge

Where the agents live, and the door through which workflow applications drive them.

What it does

Runs each agent's loop: ask the model, carry out the tool calls it proposes, wait when one is held, carry on when a person replies. As a bridge it also accepts the OpenAI chat format and the Model Context Protocol, with one API key per agent.

What it holds

Each agent's private key, on its own storage. No operator or reviewer credential.

Who can reach it

The console and workflow applications, on the agents network.

If it is unavailable

No agent can act. Tasks in progress are lost, since they are held in memory.

Two agents: a data analyst and a report writer, each told about one tool its role does not include, to show the gateway enforcing the role. **Limits:** it states the person's name to the gateway, which takes it on trust.

LangGraph workflow

Agents orchestrated in code: the analyst hands its findings to the writer.

What it does

Runs the data analyst, then passes its findings to the report writer. Each acts under its own identity, on a model chosen per agent. Both share one task identifier, so the ledger shows the hand-over as one task.

What it holds

The agents' API keys for the bridge. Never their private keys.

Who can reach it

Nobody: it is run on demand from the command line, and it reaches only the bridge.

If it is unavailable

Nothing else is affected. The console can still give agents tasks.

Limits: no person is recorded for its tasks. The hand-over is inside the workflow: there is no delegated credential between agents.

Console

The human side: one web page where people give tasks, reply and review.

What it does

A requester gives an agent a task and replies to it. A reviewer approves or rejects held calls and sees flags. An operator enrolls agents. Each step is shown with the gateway's decision and its trace identifier.

What it holds

Personal accounts with hashed passwords and roles. The operator, reviewer and runtime keys. No agent key.

Who can reach it

A browser on the same machine. It is the only published port in the build.

If it is unavailable

Nobody can review, so held calls expire and are denied. Workflows still run.

Why accounts matter: the signed-in name travels with every call, so the ledger shows who asked. **Limits:** the person is verified here, not at the gateway. Sign-in is basic.

Mock tools

Stand-ins for the organisation's real tools, internal or external.

What it does

Answers as a database read, a file read, a report generator, an export and a delete would. Counts the calls it receives, so a test can prove that a refused call never arrived.

What it holds

A small fixed set of sales figures and one set of notes. No credentials.

Who can reach it

The gateway only. Agents hold no credential for any tool and have no route to one.

If it is unavailable

Tool calls fail. The decision and its record are still made.

Limits: these are not real tools. The file read returns the same notes for any path, which hid a model's made-up file name.

Verifier and audit trail tools

Two command-line tools that check and read the ledger, and owe nothing to the system they check.

What they do

The verifier recomputes every hash from the ledger files and reports a backward timestamp separately, as a clock warning. The audit trail tool prints one task's entries in plain words, with who asked, and can alter a copy to show tampering being caught.

What they hold

Nothing. They need the ledger's hashing secret to recompute the hashes, and share no code with the ledger.

Who can reach them

They are not a service. They run with no network at all, on a read-only view of the ledger.

Why they exist

The ledger's own check twice called a sound chain invalid: after rotation, and after a clock step.

Observed: three of three alterations of a ledger copy detected. **Limits:** they cannot tell that the end of the ledger was cut off unless the last hash was noted elsewhere.